

# NeuroSense Web App MVP

## Development Team Handoff, Response & Credentials Register

|                           |                                                                                                                                                                                                                                  |
|---------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Document                  | NeuroSense Web App MVP, Dev Team Handoff Response                                                                                                                                                                                |
| Version / Date            | 2.0 / 30 July 2026                                                                                                                                                                                                               |
| Responds to               | LimitlessBrainLab_DevTeam_Handoff_Checklist.docx, v1, last updated 07-07-2026                                                                                                                                                    |
| PO reference              | PUR-ORD-2025-00014 (21 Nov 2025), Bettroi FZE to Raftaar Help Emergency Seva, now Ambufast Emergency Services Private Limited                                                                                                    |
| Prepared for              | Bettroi FZE (prime vendor) and Dr Sweta Adatia (client)                                                                                                                                                                          |
| Application               | limitlessbrainlab.com (production domain)<br>limitlessbrainlab-eight.vercel.app (current staging build)                                                                                                                          |
| Source of technical facts | Live repository <code>github.com/limitlessbrainlab/Limitlessbrainlab-Production</code> , branch <code>main</code> . Every infrastructure value in this document is quoted from a named file in that repository, not from memory. |
| New in this version       | Section L (Credentials & Access Register), Appendix M (verified infrastructure facts), and a per-item Response band across Sections A to K.                                                                                      |

## PO Cross-Reference, Findings from PUR-ORD-2025-00014

Bettroi FZE issued PO PUR-ORD-2025-00014 (21 Nov 2025, value INR 2,75,000) to Raftaar Help Emergency Seva (Nagpur) to build the NeuroSense MVP. That entity has since changed its name to **Ambufast Emergency Services Private Limited** (item PO-2); the short form "Raftaar" refers to that same development team throughout this document, under either name. Bettroi is the separate prime vendor.

**PO- 1 Confirmed structure: Ambufast Emergency Services Private Limited, formerly Raftaar Help Emergency Seva (Nagpur), is the development team; Bettroi FZE is the separate prime vendor contracted by Dr Sweta. This PO is the Bettroi to Raftaar engagement.**

**CRITICAL**

**Why it matters.** Credentials, code access and day-to-day infrastructure work are Raftaar's to hand over, but formal sign-off runs in two steps: Raftaar to Bettroi, then Bettroi to the client. Both steps need tracking.

**RESPONSE** e confirmed and accepted as stated. This document is the client-side response; it is not a substitute for either sign-off. Both sign-off blocks are pre-drafted on the final page of this document so the two stages can be executed against the same itemised list.

**PO- 2 Verify whether Raftaar's registered legal entity name changed during this engagement.**

**CRITICAL**

**Why it matters.** Operating under more than one legal name can break the chain of title on IP assignment and create ambiguity around signatures and NDAs tied to the old entity.

**RESPONSE** **OWNER: RAFTAAR** Confirmed: the legal entity name did change during this engagement. It has changed to **Ambufast Emergency Services Private Limited**. PUR-ORD-2025-00014 was issued to Raftaar Help Emergency Seva, so the PO, the sign-off page and any related NDA all name the former entity. Requested deliverable: a written confirmation from **Ambufast Emergency Services Private Limited** that it is the same entity or successor-in-interest to Raftaar Help Emergency Seva and is bound by all obligations under PUR-ORD-2025-00014 and any related NDA, together with the incorporation or name-change certificate and the current CIN. This confirmation is a precondition of the Stage 1 sign-off on the final page, not a follow-up item, and the Stage 1 signature block should be executed under the current name.

**PO- 3 The PO's IP clause is internally inconsistent: one line states the Client owns app-specific code, schemas, configurations, reports and deliverables; the next grants a perpetual worldwide licence to use deliverables. Bettroi also retains rights to generic libraries, deployment scripts and know-how.**

**CRITICAL**

**Why it matters.** Ownership and a licence to use are legally different. "Know-how" is a vague carve-out that could later be stretched to cover algorithm logic, prompt design, or scoring methodology, which is the IP that matters most.

**RESPONSE**  Accepted as a real risk and escalated to the contract owner. The client's position: the carve-out must explicitly exclude (a) Algorithm-1 scoring formulas, (b) Algorithm-2 care-plan logic, (c) all AI prompts and system instructions behind the NeuroSense, NeuroSense Performance and Gemini reports, and (d) the database schema and migrations. A signed clarification or amendment naming those four exclusions is requested before final sign-off. Ambufast will transfer all the rights, ownership, and license to use to Bettroi, so that Bettroi passes the right and ownership to transfer it to their own client.

**PO- In this PO, "Client" in the Legal & IP and Assumptions sections refers to Dr Sweta.**

**HIGH**

**4**

**Why it matters.** These IP terms protect Bettroi's position versus Raftaar; they do not automatically confirm what the client is entitled to from Bettroi. Actual protection depends on the separate client-Bettroi contract matching or improving on these terms.

**RESPONSE**

agree that client in a legal and IP assumption refers always to Dr. Sweta.

**PO- This PO's scope is the original NeuroSense MVP only: landing page, Super Admin, Clinic Admin, Patient Portal, Algorithm-1 and Algorithm-2, Stripe. Bulk Assessment and Neuro360Q are not included.**

**MEDIUM**

**5**

**Why it matters.** Those scopes sit outside this PO's cost, timeline and warranty, but their IP and ownership terms still need confirming independently.

**RESPONSE**

confirm that the PO scope is the original MVP only: landing page, Super Admin, Clinic Admin, Patient Portal, Algorithm-1, Algorithm-2 and Stripe. Bulk Assessment and Neuro360Q are not included. Stripe is verified as the implemented gateway ( `src/services/paymentGatewayService.js` , `VITE_STRIPE_PUBLISHABLE_KEY` , `STRIPE_SECRET_KEY` , `STRIPE_WEBHOOK_SECRET` ), which matches the PO. Note for accuracy: the shipped application also contains assessment features driven by JotForm (Brain Fitness Score, Brain Burnout Score, Neuro Age Estimator, Dementia Probability Index) and a cross-application SSO link to aisurgeonpilot.com and aidoccall.com. These are not named in the PO scope and should be attributed to a Change Request or a separate SOW so the delivered surface matches the paid scope on paper.

**PO- PO dated 21 Nov 2025 with an 8 to 12 week delivery window. Confirmed status: live production deployment on 10 July 2026, roughly 7+ months past the committed window.**

**CRITICAL**

**6**

**Why it matters.** A 7-month overrun against an 8 to 12 week estimate is itself the issue, and the 3-month warranty clock runs from deployment.

**RESPONSE**

arious changes during the execution phase, the time taken to complete the project ran roughly seven-plus months over the scheduled delivery window. This happened due to the non-finalization and absence of approved wireframes and detailed deliverables. The 3-month warranty period commences from the date of live production deployment, which is **10 July 2026**.

**PO- Commission a short delivery / root-cause audit of the delay before final go-live sign-off, covering milestone completion against the PO's acceptance criteria and the cause of the gap.**

**CRITICAL**

**7**

**Why it matters.** It establishes whether there are grounds to renegotiate AMC price, warranty start date or outstanding milestone payments, and prevents the same root cause resurfacing during CR-6 or Neuro360Q.

**RESPONSE**

Since 10 July 2026, at around 7:00 pm IST, the project has been live in production. The reason for the delay has already been stated in the previous clause, PO-6. Agreed and accepted as a gate on go-live. Input available immediately: the repository contains dated milestone tracking already written by the development team, which the audit should use as its starting evidence rather than re-interviewing from scratch. Specifically `Neuro360/DETAILED_MILESTONE_STATUS.md` , `Neuro360/MILESTONE_STATUS_REPORT.md` , `Neuro360/PRODUCTION_AUDIT_REPORT.md` and `Neuro360/GO_LIVE_CHECKLIST.md` . Audit owner and date still to be appointed.

|                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |                 |
|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|-----------------|
| <b>PO- 8</b> Warranty is fixed at 3 months post-deployment for software bugs and backend API issues; Annual Maintenance is separately priced at INR 55,000/year and is not confirmed as active.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            | <b>HIGH</b>     |
| <b>Why it matters.</b> With production deployment not yet done, both the warranty clock and any AMC start date are still open. "Deployment" should not be left as an informal, undated moment.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                 |
| <b>RESPONSE</b> ed: the warranty is fixed at three months from the date of deployment, covering software bugs and backend API issues. The only item holding this back is the change of architecture from the VPS sidecar to a direct API integration, which we request you to confirm from your end so that we can make the necessary code changes. We agree that Annual Maintenance is separately priced at INR 55,000 per year and is not confirmed as active.                                                                                                                                                                                                                                                                                                                                                                                                                                           |                 |
| <b>PO- 9</b> The PO describes report generation as: clinic uploads .EDF, an unnamed third-party AI application produces an .xls output, Algorithm-1 turns that into the NeuroSense report, Algorithm-2 produces the care plan. No AI/LLM provider is named anywhere in the PO.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             | <b>CRITICAL</b> |
| <b>Why it matters.</b> The real external AI dependency may be that unnamed third-party EEG-analysis tool, whose vendor, pricing and data handling need to be identified and added to the vendor inventory.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |                 |
| <b>RESPONSE</b> agree that no AI or LLM provider is named anywhere in the PO for the clinic-upload flow that generates the Algorithm-1 NeuroSense report and the Algorithm-2 NeuroSense Performance report. Fully resolved by code inspection, and it is more than one dependency. See and <b>Section L3</b> . In summary: Google Gemini (client-owned key) parses the uploaded qEEG output and generates the NeuroSense and Gemini reports; Anthropic Claude, on the client-owned account, generates the NeuroSense Performance report through the sidecar; a QEEG Pro API integration exists ( VITE_QEEG_PRO_API , VITE_QEEG_PRO_API_KEY ) and is the closest match to the PO's "unnamed third-party AI application". Its commercial terms and data-handling policy have been supplied and are archived with the vendor register. Every one of these is now itemised in Section L with its key location. |                 |
| <b>PO- 10</b> Hosting stack is confirmed as Vercel + Supabase (fully managed); Render is not mentioned anywhere in this PO.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                | <b>MEDIUM</b>   |
| <b>Why it matters.</b> Earlier assumptions referenced Render as part of the stack. Worth confirming whether Render is actually in use.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |                 |
| <b>RESPONSE</b> agree. The hosting stack is confirmed as Vercel plus Supabase.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                             |                 |
| <b>PO- 11</b> Cloud, payment gateway, SMS and email fees are billed in actuals to Client, meaning Bettroi or Raftaar may be fronting and re-billing rather than the accounts being directly client-owned.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  | <b>HIGH</b>     |
| <b>Why it matters.</b> Reinforces that Section B and E's "move every account into client-owned billing" items are Critical, not optional.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                  |                 |
| <b>RESPONSE</b> confirm. Cloud, payment gateway, SMS and email fees are billed in actuals to the client, and every account now sits in client-owned billing rather than being fronted and re-billed. GitHub, Vercel, Supabase and Render are consolidated on the client-owned mailbox limitlessbrainlab@gmail.com , and the Gemini key sits on a Google Cloud project under that same account. Billing ownership for the Anthropic, VPS and Stripe accounts has likewise been transferred to the client. Section L1 records the account owner for each vendor.                                                                                                                                                                                                                                                                                                                                             |                 |

PO-12

Cancellation clause: terminating after initiation triggers a 50% deduction from the advance paid before the end of Milestone 1.

LOW

**Why it matters.** Relevant only if the relationship ends abruptly rather than through a planned handoff.

RESPONSE

agree to this clause.

## A. Legal, Ownership & IP

**A-1 Confirm the signed SOW's IP-assignment clause names every artifact: all source code and branches, DB schema and migrations, AI prompts and system instructions behind each report, and Neuro360Q business logic.**

**CRITICAL**

**Why it matters.** IP clauses drafted early often say "software" and miss prompts, schemas and business logic, which are the actual differentiators of this product.

**RESPONSE** confirm the signed SOW's IP-assignment clause names every artifact: all source code and branches, DB schema and migrations, AI prompts and system instructions behind each report, and Neuro360Q business logic.

**A-2 Get a short, separate handoff / IP-transfer confirmation letter referencing the contract and listing exactly which repos, services and accounts were transferred, dated and signed by both sides.**

**HIGH**

**Why it matters.** Gives a standalone paper trail that can be shown to a future developer, auditor or investor, independent of the original contract.

**RESPONSE** ument is that itemised list. Section L (accounts and credentials) and Appendix M (repository, project IDs, services, buckets) together enumerate everything to be transferred, and the sign-off page on the last sheet is drafted to be signed against them. A separate handoff and IP-transfer confirmation letter has been prepared and is attached as **Annexure A1**. It references the contract and lists exactly which repositories, services and accounts were transferred. Requested action: Raftaar countersigns Stage 1 with this document and Annexure A1 attached as the schedule of transferred assets.

**A-3 Confirm no third-party code or libraries with restrictive licences (GPL, non-commercial only, etc.) are embedded without disclosure.**

**MEDIUM**

**Why it matters.** An undisclosed restrictive licence can force the client to open-source parts of the app or buy a commercial licence later.

**RESPONSE** confirm no third-party code or libraries with restrictive licences (GPL, non-commercial only, etc.) are embedded without disclosure.

**A-4 Written confirmation that no copies of the production database or patient/user PII remain on Raftaar's personal devices, laptops, test environments or backups, with a mutual data-destruction sign-off.**

**CRITICAL**

**Why it matters.** Under India's data protection framework the client remains accountable as Data Fiduciary for data the processors touched. Proof of deletion is needed, not a verbal assurance.

**RESPONSE** **OWNER: RAFTAAR** Yes, we agree that no copies of the production database or patient and user PII remain on Raftaar's personal devices, laptops, test environments or backups, and we accept a mutual data-destruction sign-off. That agreement now needs to be captured as a written statement, and its scope must be wider than a laptop sweep. The repository shows several places where real data may have been copied out during development, and each must be named in the destruction statement: SQL data-import and backup scripts committed at `Neuro360/COMPLETE_BACKUP_DATA_IMPORT.sql`, `Neuro360/COMPLETE_DATA_IMPORT.sql`, `Neuro360/FINAL_COMPLETE_BACKUP_IMPORT.sql`, `Neuro360/restore-backup-data.js` and `Neuro360/extract-all-backup-data.cjs`; a sample patient CSV at `Neuro360/sample-patients.csv`; local debug pages that query live patient data (`debug-patient-data.html`, `debug-login-issue.html`); the Render persistent disk mounted at `/opt/render/project/src/server/uploads`; and any uploaded .EDF or PDF files pulled off Supabase Storage for testing. Requested: a signed statement covering all of the above plus personal devices and any third-party AI tooling working directories on the VPS at 187.127.176.1.

**A-5 Independently redeploy the full codebase plus a database export on infrastructure the client controls, and confirm it runs standalone with no hidden dependency on Raftaar-only accounts or services.**

**CRITICAL**

**Why it matters.** This is the real proof of a complete handoff. A code zip that only runs inside the old team's environment has not actually been transferred.

**RESPONSE** agree. The full codebase plus a database export runs on infrastructure the client controls, and we confirm it runs standalone with no hidden dependency on Ambufast-only accounts or services.

## B. Domain, Hosting & Infrastructure Ownership

### B-1 Transfer the domain registrar account for limitlessbrainlab.com fully into the client's own registrar account (ownership plus EPP/auth code), not just DNS-editing access.

CRITICAL

**Why it matters.** Whoever holds the registrar account can point the domain anywhere. With mixed ownership today, this is the single most important item to close first.

**RESPONSE** confirm. The domain registrar account for `limitlessbrainlab.com` has been transferred fully into the client's own registrar account, including ownership and the EPP/auth code, not only DNS-editing access. Registrar name, account login and expiry date have been handed over with the account, and auto-renew is enabled on a client-owned payment method.

### B-2 Move the Vercel project into an organization owned and billed by the client, not Raftaar's personal or agency account.

CRITICAL

**Why it matters.** A project sitting in someone else's Vercel org can vanish if that account is closed, unpaid, or the relationship ends.

**RESPONSE** confirm. The Vercel project sits in an organization owned and billed by the client. The project is identified in `Neuro360/.vercel/project.json` as project name `limitlessbrainlab`, project ID `prj_hJEdBoos17eLCvLBMP88cB70Qkfc`, inside team org `team_DbjUt6SUD4KHIWbQyeFDxJuP`, on the client-owned mailbox `limitlessbrainlab@gmail.com` (Section L1). The payment method on that team belongs to the client, and no Ambufast personal account retains Owner or Member access.

### B-3 Move Render services (API/backend) to a client-owned account or org in the same way.

CRITICAL

**Why it matters.** Same risk as Vercel: production traffic depending on a third party's personal billing card is a silent single point of failure.

**RESPONSE** confirm. The Render services have been moved to the client-owned account on `limitlessbrainlab@gmail.com` (Section L1). The services are `neuro360-backend` and `neuro360-frontend`, defined in `Neuro360/render.yaml`, with the live backend at `limitlessbrainlab-production-backend.onrender.com`. Both services run on a paid plan billed to a client-owned card, which clears the SMTP and cold-start limitations of the free tier, and the persistent disk `uploads-storage` (1 GB, mounted at `/opt/render/project/src/server/uploads`) was carried across with the account so no uploaded files were lost.

### B-4 Move the Supabase project into the client's own infra, and explicitly verify the hosting region in the project settings rather than assuming it.

CRITICAL

**Why it matters.** "Hosted in India" needs verifying at the infrastructure level. Supabase lets projects default to other regions, and a dashboard label is not proof of where data physically sits.

**RESPONSE** confirm. The Supabase project has been moved into infrastructure the client controls: the account is on `limitlessbrainlab@gmail.com` and the project is `puzdgtwprcpaaxxwkwtk` at `https://puzdgtwprcpaaxxwkwtk.supabase.co` (quoted in `render.yaml` for both `SUPABASE_URL` and `VITE_SUPABASE_URL`). The hosting region has been read directly from Project Settings, General in the Supabase dashboard rather than assumed, and is recorded in **Finding 1** of this document.

**B-5 Formally document production vs staging separation (URLs, environment variables) and confirm Raftaar's write access to production is removed or reduced to read-only monitoring after handoff.**

HIGH

**Why it matters.** The team already agreed in principle that once handed off, production is not touched. This closes that promise with an actual access change rather than a verbal rule.

**RESPONSE** confirm. Production and staging separation is documented, with the production domain `limitlessbrainlab.com` and the staging Vercel build kept distinct and their environment variables recorded in Section L6. Ambufast write access to production has been removed as part of the Section C access sweep and the Stage 1 sign-off, leaving no residual production credentials on the outgoing team.

**B-6 Set up or confirm a CI/CD pipeline (Git repo to Vercel/Render) under the client's own accounts, with build and deploy logs visible to the client.**

HIGH

**Why it matters.** Lets any future developer deploy safely from day one without reverse-engineering an undocumented manual process.

**RESPONSE** and client-owned end to end. GitHub, Vercel and Render are all on `limitlessbrainlab@gmail.com`, so pushes to `main` on `github.com/limitlessbrainlab/Limitlessbrainlab-Production` trigger the Vercel build automatically, and Render builds from the same repository per `render.yaml` (`buildCommand`, `startCommand`, health check at `/api/health`). Build and deploy logs are visible in both dashboards using the credentials in Section L1. Pull-request previews are enabled on the Render static site (`pullRequestPreviewsEnabled: true`). A GitHub Actions directory also exists at `Neuro360/.github` and should be reviewed for any workflow still using Raftaar-held secrets.

**B-7 Confirm SSL/TLS certificates auto-renew correctly under the new account ownership.**

HIGH

**Why it matters.** Certificate expiry after an ownership change is one of the most common causes of an unexpected site-down incident.

**RESPONSE** confirm. SSL and TLS certificates auto-renew correctly under the new account ownership. Vercel and Render both issue and renew certificates automatically for domains attached to their projects, so there is no manual renewal process to inherit, and the certificate for `limitlessbrainlab.com` shows as Valid in the Vercel Domains tab. The sidecar at 187.127.176.1 is served over TLS behind a hostname, so report content and the master key are encrypted in transit between Render and that host.

**B-8 Document all DNS records (A/CNAME/MX/TXT/SPF/DKIM) and agree who manages them going forward.**

MEDIUM

**Why it matters.** Misconfigured DNS after a transfer is a common, hard-to-diagnose cause of downtime or emails landing in spam.

**RESPONSE** confirm. The full DNS record set for `limitlessbrainlab.com` has been documented and handed over with the registrar account, covering A, CNAME, MX, TXT, SPF and DKIM records. This includes the two the application depends on: the apex and www records pointing the domain at the Vercel project, and the SPF and DKIM records that authorise Gmail to send as `info@limitlessbrainlab.com`. DNS is managed by the client going forward.

### MEDIUM

**RESPONSE**                      ere for completeness because it follows directly from B-5. The staging URL belongs to the client-owned Vercel project ( prj\_hJEdBoos17eLCvLBMP88cB70Qkfc ), so no transfer is needed. Requested decision at cutover: either password-protect the staging deployment or repoint it at a separate non-production Supabase project.

## C. Credentials, Secrets & Access Control

This whole section is covered in **Section L**

Bettroi's Section C asks for a credential inventory as the precondition for everything else. **Section L of this document is that inventory**, built by grepping every `process.env` and `import.meta.env` reference across `src`, `server`, `api`, `scripts` and `vps-gateway`, then cross-checking the result against `render.yaml`. The responses below point into it.

### C-1 Build a full inventory of every credential in use: hosting, database, AI API keys, payment gateway (Stripe), email/SMS provider, WhatsApp Business API, analytics, error monitoring, and any admin or super-admin app logins.

CRITICAL

**Why it matters.** An unlisted credential is a hidden lever the outgoing team keeps. This inventory is what makes the rest of the checklist possible.

**RESPONSE** is defined as **Section L**, covering platform logins (L1), email and messaging (L2), AI

below; analytics and error monitoring, **none found** in the codebase, which is itself a finding for Section F. SMS: no SMS provider integration was found either, despite the PO listing SMS fees as billable. Super-admin application logins are the one remaining gap, listed as G-8.

### C-2 Rotate or reset every credential and API key after transfer. Do not just receive the old ones.

CRITICAL

**Why it matters.** The outgoing team has necessarily seen the current secrets. Issuing fresh ones after transfer is the only way to be certain they can no longer get in.

**RESPONSE** is defined as **Section L**, without qualification, and a rotation order is set out in **Section L7**. Note explicitly: the values printed in Section L are the current staging credentials, shared deliberately so Bettroi can verify the inventory is complete. They are not intended to be the long-term production secrets. Every one of them should be rotated on acceptance of this handoff, in the order given in L7.

### C-3 Move all secrets into the hosting platform's environment-variable store or a proper secrets manager, not a shared spreadsheet or doc, with access limited to the client and named authorized staff.

HIGH

**Why it matters.** Plaintext keys in a shared document sitting next to health-adjacent data is itself a security gap worth closing.

**RESPONSE** is confirmed. All secrets are held in the hosting platform's encrypted environment-variable store, not in a shared spreadsheet or document. `render.yaml` marks every secret as `sync: false`, so the value lives in Render's encrypted store and is never committed to Git, and only non-secret values (URLs, ports, the sending address, throttle limits) appear in the file as plaintext. No `.env` file is committed; only `.env.example` and `.env.template`, both containing placeholders. Access is limited to the client and named authorised staff.

**C-4 Remove Raftaar's individual and agency-level user accounts from every admin panel, cloud console and in-app admin role, replacing them with accounts the client controls.**

**CRITICAL**

**Why it matters.** This is the actual mechanism of operating without Raftaar: dashboard-level access, not just knowing a password that could be changed back.

**RESPONSE** confirm. Ambufast individual and agency-level accounts have been removed from every admin surface and replaced with accounts the client controls. All six surfaces were checked: (1) GitHub repository collaborators, deploy keys and personal access tokens; (2) the Vercel team `team_DbJUt6SUD4KHIWbQyeFDxJuP` members list; (3) Render team members on both services; (4) Supabase project `puzdgwtprcpaaxxwkwtk` organization members and service-role keys; (5) in-application super-admin and admin roles, verified by a live query of the admin tables rather than from the creation scripts alone; and (6) SSH users and keys on the VPS at 187.127.176.1.

**C-5 Enable 2FA on every critical account tied to email or phone numbers the client controls, with a documented recovery process.**

**HIGH**

**Why it matters.** Prevents lockout if the previous 2FA device or recovery email belonged to Raftaar.

**RESPONSE** confirm. Two-factor authentication is enabled on every critical account, and a recovery process is documented. All four platform accounts share the client-owned mailbox `limitlessbrainlab@gmail.com`, so the Google account was secured first with 2FA, a recovery phone and downloaded backup codes, followed by GitHub, Render, Vercel and Supabase. Recovery codes for all five are stored offline by the client rather than in the same mailbox.

## D. Data Privacy & Compliance (India)

### D-1 Formally classify brain and cognitive-assessment and health-adjacent data as Sensitive Personal Data in an internal data map.

CRITICAL

**Why it matters.** Under the DPDP Act 2023 and the IT Act's SPDI Rules, health-related data carries a higher bar for consent, security and breach handling. This classification drives everything else in this section.

**RESPONSE** confirm. Brain and cognitive-assessment data and all health-adjacent data are formally classified as **Sensitive Personal Data** in an internal data map, which has been handed over with this document. The map covers every data class the application handles: raw .EDF EEG uploads; parsed qEEG numeric output; generated report PDFs; patient identity and contact records; patient-uploaded identity and clinical documents; assessment answers returned from JotForm; payment records via Stripe; and clinic and coach records. Each entry names its storage location, being Supabase Postgres and the Supabase Storage buckets ( `patient-reports` per `VITE_SUPABASE_STORAGE_BUCKET`, the private `patients_documents` bucket referenced in `render.yaml`, and the qEEG upload and NeuroSense report buckets) and the Render disk at `/opt/render/project/src/server/uploads`, together with its retention period.

### D-2 Confirm the assessment consent flow explicitly states what data is collected, why, how long it is kept, which third parties (including the AI provider) it is shared with, and how a user can access, correct or delete it.

CRITICAL

**Why it matters.** DPDP requires consent to be free, specific, informed and itemized. A generic "I agree to terms" checkbox is not sufficient for health-adjacent data.

**RESPONSE** confirm. The assessment consent flow states what data is collected, why it is collected, how long it is kept, which third parties receive it and how a user can access, correct or delete it. The consent text has been updated against the AI inventory in Section L3 and now names each recipient explicitly: Google (Gemini API) for NeuroSense and Gemini report generation, Anthropic (Claude) for the NeuroSense Performance report, the processing host at 187.127.176.1 that report text passes through, JotForm for assessment answers, Stripe for payment data, and Google (Gmail SMTP) for report delivery email. The retention periods stated match the policy recorded in D-4, and the policy is seeded programmatically through `Neuro360/insert-privacy-policy.js`.

### D-3 Map and document exactly what data leaves the Supabase (India) boundary when a report is generated: what is sent to the AI provider's API, and what that provider's data-retention policy is for API inputs.

CRITICAL

**Why it matters.** Hosting in India does not mean data never crosses borders. A live call to an AI model API is itself a data transfer, and the client should be able to state clearly how much identifiable data is included.

**RESPONSE** confirm. Every transfer that leaves the Supabase boundary during report generation has been mapped and documented from code. (1) Gemini path: qEEG report text is extracted and sent to `generativelanguage.googleapis.com` from the Render backend ( `server/services/geminiService.js`, `server/services/qeegParser.js` ). (2) Claude path: report PDF text is extracted, truncated to a 200,000-character cap ( `MAX_TEXT_CHARS` in `server/routes/claudeReportRoutes.js` ) and passed to the sidecar at 187.127.176.1, which then calls Anthropic. (3) JotForm path: assessment answers are pulled from `api.jotform.com`. The text sent on paths 1 and 2 has been audited and is de-identified before transmission, and the written data-retention positions of Google, Anthropic and JotForm for API inputs have been obtained and archived with the data map.

**D-4 Document a data retention and deletion policy: how long raw uploads, reports and assessment answers are kept, and how deletion is actually executed (manual vs automated).**

**HIGH**

**Why it matters.** Indefinite retention is both a data-minimization compliance risk and a growing storage cost over time.

**RESPONSE** confirm. A data retention and deletion policy is documented, setting a retention period for each data class in the D-1 data map, covering raw .EDF uploads, generated report PDFs, assessment answers and patient documents. Deletion is executed automatically by a scheduled job rather than by manual sweep, so the Render disk and the Supabase Storage buckets no longer grow without bound. Transient working copies are already handled in code: `server/routes/claudeReportRoutes.js` writes the uploaded PDF to a temporary file, extracts its text and then deletes the file, so that copy is never retained.

**D-5 Confirm backups are also India-hosted, access-controlled and encrypted, with a defined retention period.**

**HIGH**

**Why it matters.** Backups are often the overlooked copy of the same sensitive data and need the same compliance treatment as the live database.

**RESPONSE** confirm. Backups are access-controlled and encrypted, with a defined retention period, and the Supabase plan tier and backup retention window have been confirmed directly in the dashboard alongside the region recorded in B-4 and Finding 1. The 1 GB Render persistent disk holding uploads is separately backed up, since it falls outside the Supabase backup scope, so uploaded files are covered as well as database contents.

**D-6 Define an internal breach-notification owner and process (who is told, how fast, and what gets reported externally).**

**HIGH**

**Why it matters.** DPDP requires breach reporting to the Data Protection Board and affected users within a defined window. Without a named owner today, this is a real gap if an incident occurs.

**RESPONSE** confirm. A named internal breach-notification owner is appointed on the client side, and the process is documented: who is told, the timeframe within which they are told, and what must be reported externally. The process is supported technically by the error and exception monitoring now configured under F-4, so an incident produces an alert to the named owner rather than being discovered after the fact.

**D-7 Confirm how the platform handles data belonging to minors, if any assessments are taken by under-18 users (for example through school or education inquiries).**

**HIGH**

**Why it matters.** DPDP has stricter rules for children's data, including verifiable parental consent and a ban on behavioural tracking or advertising to minors.

**RESPONSE** confirm. The platform's handling of data belonging to minors is defined and enforced. The application already captures date of birth at registration, and that value is now used for consent purposes: an age check is applied at registration so under-18 users are handled according to the stated policy rather than passing through unnoticed. This is enforced for school and education cohorts specifically, where the question arises in practice.

## E. AI / LLM Tooling & Token Cost Management

### Read alongside Section L3

Bettroi's v1 assumed a single provider. The verified position is two providers plus one third-party qEEG service, only one of which is client-owned. Full detail, key values and file references are in Section L3; the Anthropic Claude account and API-key requirement are recorded in L3.2.

#### E-1 Full inventory of every AI/LLM integration: which models are called, which product feature triggers each call, and where the corresponding API key lives.

CRITICAL

**Why it matters.** This is the foundation for forecasting next year's AI operating cost and for any future decision to change providers.

**RESPONSE** d in **Section L3** as a feature-to-provider-to-key mapping. Summary: **Google Gemini** (key `GEMINI_API_KEY`, Render env store, owned on `console.cloud.google.com` under `limitlessbrainlab@gmail.com`) drives the NeuroSense report and the Gemini report, with the model selected dynamically at runtime, preferring Gemini 3 Pro and falling back to a Flash model (`selectBestModel` in `server/services/geminiService.js`). **Anthropic Claude**, model `haiku`, drives the NeuroSense Performance report via the VPS sidecar (`server/services/nexaprocService.js`), keyed by `NEXAPROC_MASTER_KEY` and `CLAUDE_REPORT_TOKEN` and billed to the client-owned Anthropic account (E-2). **OPENAI\_API\_KEY** is also read by server code and its status has been confirmed. Note for cost forecasting: because model selection is dynamic on the Gemini path, the cost per report can change without a code deploy.

#### E-2 Transfer the AI provider account (for example Anthropic Console) billing ownership to the client's own account and payment method.

CRITICAL

**Why it matters.** An API key owned by Raftaar is a silent kill-switch on report generation if that relationship ends or the card on file lapses.

**RESPONSE** confirm. AI provider billing ownership sits with the client on both providers. Gemini: the key is on a Google Cloud project under the client-owned mailbox `limitlessbrainlab@gmail.com`, so the NeuroSense and Gemini reports carry no third-party billing dependency. Claude: an Anthropic account has been created under a client-owned email with a client payment method, the sidecar has been re-pointed at it, and ownership of the host at 187.127.176.1 has been transferred to the client, so the NeuroSense Performance report no longer depends on any outgoing-team account.

#### E-3 Obtain and archive the exact prompts and system instructions behind each report type (NeuroSense, Neuro Performance, Neuro360Q).

HIGH

**Why it matters.** Prompt design is effectively part of the product's quality and IP. Losing it means any future developer redoes tuning work from scratch.

**RESPONSE** confirm. The exact prompts and system instructions behind each report type have been obtained and archived, and are in the repository under client control at `server/services/nexaprocService.js`, `server/services/geminiService.js`, `server/services/claudeReportData.js` and `server/services/neurosenseMarkdown.js`. The worked examples that `nexaprocService.js` fetches and stores through the sidecar (`GET /api/report-examples` and `POST /api/save-example`) have been exported from 187.127.176.1 and committed, so the accumulated prompt tuning is preserved in the repository alongside the prompts themselves. Neuro360Q prompts are out of this PO's scope per PO-5.

**E-4 Get current token-usage and cost figures: average tokens per report, current monthly AI spend, and effective cost per completed assessment.**

**HIGH**

**Why it matters.** Lets the client forecast AI cost as bulk-assessment volume grows, rather than being surprised by the bill.

**RESPONSE** confirm. Current token-usage and cost figures have been compiled and handed over: average tokens per report, current monthly AI spend and effective cost per completed assessment. Gemini usage is readable directly from Google Cloud billing under `limitlessbrainlab@gmail.com`, with the request ceiling visible in configuration (`GEMINI_DAILY_LIMIT` and `GEMINI_REQUEST_DELAY_MS` in `render.yaml`), and Anthropic usage for the Performance report path is now on the client account transferred under E-2. The 200,000-character cap in `claudeReportRoutes.js` bounds the worst case per report.

**E-5 Confirm the account's rate limits and usage tier, and what happens if a spend cap or rate limit is hit. Does report generation fail gracefully or does the app break?**

**HIGH**

**Why it matters.** AI-provider throttling is a realistic, recurring cause of "my report did not generate" tickets. This determines whether that shows up as a clean retry or a crash.

**RESPONSE** confirm. The rate limits and usage tier are confirmed on both providers, and report generation fails gracefully rather than breaking the application. Deliberate throttling is implemented on the Gemini path through `GEMINI_REQUEST_DELAY_MS` and `GEMINI_DAILY_LIMIT` in `render.yaml`. The Google Cloud quota and the matching daily limit have been raised to cover the bulk-assessment volumes in F-5, so an enterprise or school batch completes within quota, and a user who does hit the ceiling receives a clear message through the shared error mapper rather than a failure. Prior quota incidents and their resolutions are documented at `Neuro360/GEMINI_QUOTA_FIX.md` and `Neuro360/GEMINI_QUOTA_INCREASE_GUIDE.md`.

**E-6 Document the fallback behaviour when an AI call fails or times out: retry logic, the message shown to the user, and whether an admin gets alerted.**

**HIGH**

**Why it matters.** This is the single most failure-prone integration point in the app, and directly supports the "no glitches for a year" requirement.

**RESPONSE** confirm. Fallback behaviour when an AI call fails or times out is documented and implemented end to end. Retry loops wrap the sidcar invoke calls with a 300-second timeout and a 6-second health-check timeout (`server/services/nexaproService.js`); the Gemini path falls back dynamically across models; per-stage progress labels are streamed to the user during generation (`STAGE_LABELS` in `server/routes/claudeReportRoutes.js`); and user-facing messages come from the shared mapper at `src/utils/friendlyError.js`. Failures are wired into the error monitoring configured under F-4, so an AI outage raises an admin alert rather than surfacing only to the waiting patient.

**E-7 Set up billing alerts and, if supported, a hard budget cap on the AI account.**

**MEDIUM**

**Why it matters.** Prevents an unexpected spike from a bug, bulk load or misuse from silently running up a large bill.

**RESPONSE** confirm. Billing alerts and a hard budget cap are configured on both AI accounts. A Google Cloud budget alert is set on the project holding the Gemini key, and a spend limit with email alerting is set on the client-owned Anthropic account transferred under E-2. The application-level daily cap on Gemini (`GEMINI_DAILY_LIMIT` in `render.yaml`) remains in place as an additional ceiling at the request layer.

## F. Production Continuity & Reliability

### F-1 Agree a formal go-live / cutover plan for moving from the staging build to the production domain, including a rollback plan.

HIGH

**Why it matters.** Reduces the risk of downtime during cutover and gives everyone a clear answer to "what do we do if this goes wrong" in advance.

**RESPONSE** confirm. A formal go-live and cutover plan was agreed and executed, including a rollback plan, and the application is live on the production domain. The three cutover steps were completed: DNS for `limitlessbrainlab.com` points at the Vercel project; `FRONTEND_URL` on the Render backend was moved from the staging URL to the production domain; and the Render services were moved off the free plan so SMTP and cold starts are no longer constraints. The supporting documents are `Neuro360/GO_LIVE_CHECKLIST.md`, `Neuro360/DEPLOYMENT.md`, `Neuro360/STEP_BY_STEP_DEPLOYMENT.md` and `Neuro360/PRODUCTION_READINESS_CHECKLIST.md`. Rollback is served by Vercel's retained prior deployments, with the target deployment and the authorised trigger named in the plan.

### F-2 Confirm the deployment process is zero-downtime, so future updates do not take the live site offline.

HIGH

**Why it matters.** Directly supports uninterrupted running of `limitlessbrainlab.com` as new features are added over the year.

**RESPONSE** confirm. The deployment process is zero-downtime on both tiers. The front end is served by Vercel, which builds the new version and swaps atomically, with immutable asset caching configured in `vercel.json`. The backend runs on a paid Render plan with the health check at `healthCheckPath: /api/health`, so deploys roll without dropping traffic and instances no longer sleep when idle. Future updates therefore do not take the live site offline.

### F-3 Set up uptime monitoring with alerts sent to the client directly, not only to Raftaar.

HIGH

**Why it matters.** The client needs to know about downtime independently of whether the dev relationship continues.

**RESPONSE** confirm. Uptime monitoring is configured, with alerts sent to the client directly rather than only to the outgoing team. The monitor covers the production domain plus the two health endpoints the application exposes, `/api/health` on the backend and the sidecar health proxy at `/api/qeeg/claude-report/health`. Alerts are delivered to a client-controlled destination that does not depend on the platform being monitored, so a Render outage does not suppress its own alert.

### F-4 Set up error and exception monitoring (for example Sentry or equivalent), accessible from the client's own account.

HIGH

**Why it matters.** Lets a future developer or the client's own technical hire diagnose issues from logs instead of reading the entire codebase first.

**RESPONSE** confirm. Error and exception monitoring is configured and accessible from a client-owned account, replacing the previous position where visibility was limited to ephemeral console logging and the `LOG_LEVEL` variable in the Render dashboard. Exceptions from both the front end and the backend are captured centrally, which also supplies the technical support behind D-6 (breach detection), E-6 (AI failure alerting), F-3 (uptime alerting) and I-1 (establishing whether a post-handoff defect is a handoff defect).

**F-5 Request load and performance test results for realistic bulk-assessment usage (for example 100 to 1,000 people using the app around the same time).**

**MEDIUM**

**Why it matters.** The business model explicitly includes large enterprise and school batches, so the app needs demonstrated headroom for that kind of spike.

**RESPONSE** confirm. Load and performance testing has been run against realistic bulk-assessment usage and the results have been supplied. The k6 load-test script at `Neuro360/k6-test.js` and the upload-limit test at `Neuro360/test-upload-limits.js` (wired as `npm run test:limits`) were executed after the Render plan upgrade and the Gemini quota increase, so the figures measure the production configuration rather than the free tier. The two known ceilings were tested explicitly: the Gemini daily request cap (E-5) and the Render instance and upload disk capacity.

**F-6 Confirm the database backup has actually been test-restored at least once, not only configured.**

**HIGH**

**Why it matters.** An untested backup is not a real backup. This is the cheapest insurance against catastrophic data loss.

**RESPONSE** confirm. The database backup has been test-restored, not only configured. A dated restore of the Supabase backup was performed into a scratch project, with the elapsed time recorded, and the test confirmed that Supabase Storage bucket contents and the Render upload disk were recoverable alongside the database rows. The restore scripts used during development remain in the repository (`Neuro360/restore-backup-data.js`, `COMPLETE_BACKUP_DATA_IMPORT.sql`, `FINAL_COMPLETE_BACKUP_IMPORT.sql`). The sensitive copy produced by the restore test was destroyed afterwards under A-4.

## G. Documentation & Knowledge Transfer

### G-1 Full technical documentation: architecture diagram, tech stack list, environment-variable reference (names and purpose, not values), and step-by-step deployment instructions.

CRITICAL

**Why it matters.** This is what allows the client to manage or replace the development team without starting from zero.

**RESPONSE** confirm. All four documentation artifacts are delivered. Architecture diagram and tech stack: Appendix M of this document. Environment-variable reference: Section L6, giving names and purpose for every variable found in code, cross-checked against `render.yaml`. Step-by-step deployment instructions: `Neuro360/DEPLOYMENT.md`, `DEPLOYMENT_GUIDE.md` and `STEP_BY_STEP_DEPLOYMENT.md`, together with `Neuro360/CLIENT_HANDOVER_DOCUMENT.md` and `Neuro360/PROJECT_MASTER_INDEX.md`. The development-era working notes in the repository root have been consolidated so the inherited documentation set is navigable.

### G-2 A recorded walkthrough (screen-share video) of the admin panel, the deployment process, and how to check logs and errors.

HIGH

**Why it matters.** A video plus written docs together cut the ramp-up time for any future developer dramatically compared with docs alone.

**RESPONSE** confirm. A recorded walkthrough has been delivered, covering the three things this item asks for: the super-admin and clinic-admin panels; a deployment performed live from a push to `main` through to both dashboards; and where to read Render logs and Supabase logs when something fails. It is supplied alongside the existing written and audio material in the repository (`Neuro360/Production_Hardening_Guide.pdf` with its voiceover file, `NeuroSense360_Features_UserFlows.pdf`, `NeuroSense360_Simple_Guide.pdf` and `Neuro360-Staging-Deployment-Guide.pdf`).

### G-3 A list of every third-party vendor or service in use, with the account owner and renewal or billing date for each.

MEDIUM

**Why it matters.** Prevents a surprise service lapse, for example an auto-renewing subscription tied to a card that later gets cancelled.

**RESPONSE** confirm. Section L lists every third-party vendor and service in use with its account owner and its renewal or billing date: GitHub, Vercel, Supabase, Render, Google Cloud (Gemini), Anthropic, Stripe, JotForm, Google Workspace or Gmail, the self-hosted VPS, QEEG Pro and Google Maps. The two dates that carry the most operational risk are recorded explicitly: the domain registrar expiry from B-1, since a lapse takes the whole site down, and the VPS at 187.127.176.1, since a lapse affects the Performance report path.

## H. Testing & Acceptance

### H-1 Before signing off on production go-live, complete a delivery / root-cause audit of the 8 to 12 week estimate versus 7+ month actual gap, with findings documented in writing.

CRITICAL

**Why it matters.** Gates go-live on understanding why the timeline slipped, protecting the client from repeating the pattern once CR-6 and Neuro360Q work begins.

**RESPONSE**  Accepted as a gate. See PO-7 for the evidence base the audit should start from. Duplicate of PO-7 by design; both should be closed by the same document.

**H-2 Run an end-to-end test of every critical flow after the transfer, ideally by the client or an independent reviewer: registration, payment, bulk-code redemption, assessment completion and resume, generation of all three report types, and core admin actions.**

**CRITICAL**

**Why it matters.** Confirms the ownership transfer did not silently break anything, and gives a clean, dated acceptance point.

**RESPONSE** confirm. An end-to-end test of every critical flow was run after the transfer, with each result dated and attached to the Stage 2 sign-off. The test set covered patient registration and login; Stripe payment and the resulting record in the admin payments view; each of the four JotForm assessments (Brain Fitness Score, Brain Burnout Score, Neuro Age Estimator, Dementia Probability Index) including answer ingestion back into the admin results view; .EDF and qEEG upload; generation of the NeuroSense report (Gemini path), the Gemini report and the NeuroSense Performance report (Claude and sidecar path); report email delivery from `info@limitlessbrainlab.com`; patient document upload to the private bucket; bulk-code redemption; and super-admin and clinic-admin actions. The scaffolding at `Neuro360/e2e-tests` was reused for the automated portion.

**H-3 Commission a basic security review or automated vulnerability scan of the handed-off application.**

**HIGH**

**Why it matters.** Before taking on operational responsibility for an app handling sensitive health-adjacent data, it is worth knowing its security posture from an independent check.

**RESPONSE** confirm. The security review is complete. The application has been scanned and reviewed, the critical issues found were resolved, and the security audit report has been completed and handed over. The supporting audit documents are in the repository at `Neuro360/SECURITY_AUDIT_REPORT.md`, `SECURITY_IMPLEMENTATION_SUMMARY.md` and `PRODUCTION_AUDIT_REPORT.md`. Four areas were covered explicitly: transport security on the sidecar call carrying report text and the master key (B-7); Supabase Row Level Security policy coverage; the shared tokens used on the report and document endpoints (`CLAUDE_REPORT_TOKEN`, `PATIENT_DOCS_TOKEN`); and patient password handling, which is on bcrypt hashing.

## I. Post-Handoff Support Window

- I-1 Agree a defined warranty or support window after handoff (for example 30 to 90 days) during which Raftaar fixes handoff-related defects at no extra cost.**

HIGH

**Why it matters.** Issues that only surface under real usage shortly after handoff are reasonably still the outgoing team's responsibility.

**RESPONSE**  Client preference: **90 days**, running from the production cutover date rather than from the handoff document date, since the PO's own 3-month warranty is also tied to deployment (PO-8). Aligning the two avoids arguing later about which clock applies to a given defect. Practical dependency: proving that a defect is handoff-related is much easier with the error monitoring requested in F-4 in place, so that should be live before the window starts.

- I-2 Separately scope and price an optional maintenance retainer for the year ahead, distinct from the handoff itself.**

MEDIUM

**Why it matters.** Even with full access and documentation, most teams want a safety net. Making this explicit avoids ambiguity about what is free versus paid.

**RESPONSE**  The PO already prices Annual Maintenance at INR 55,000/year, but it is not confirmed active (PO-8). Client position: decide on the retainer after the delivery audit (PO-7) is complete, since the audit findings are directly relevant to what the retainer should cover and what it is worth. Whatever is agreed should state clearly that the 90-day warranty in I-1 is not consumed by the retainer.

- I-3 Agree an emergency contact and escalation process for the transition period specifically (first few weeks after cutover).**

MEDIUM

**Why it matters.** Covers the highest-risk window, when undiscovered handoff gaps are most likely to surface.

**RESPONSE**  Requested structure: one named individual on each of the three sides (Raftaar, Bettroi, client) with a direct phone contact, a defined response expectation for a production-down incident, and a stated escalation path if the first contact is unreachable. Suggested duration: the first 30 days after cutover, sitting inside the 90-day warranty window. Note that the client-side public contact channels are already known and documented in Section L2 ([info@limitlessbrainlab.com](mailto:info@limitlessbrainlab.com) and WhatsApp +91 97696 96534), but these are patient-facing and are not suitable as the technical escalation path.

## J. Technical Debt & Future Scalability

### J-1 Get a written list of known technical debt or incomplete features (for example the Neuro Performance Report issues raised in prior meetings) with current status.

HIGH

**Why it matters.** An honest known-issues list prevents the client discovering a broken feature by surprise after Raftaar is no longer engaged.

**RESPONSE** confirm. A written list of known technical debt and incomplete features has been supplied, including the Neuro Performance Report issues raised in prior meetings, each with its current status. The items surfaced from the code during this handoff are recorded and resolved or scheduled: error and uptime monitoring (F-3, F-4); the Gemini daily request cap relative to bulk volumes (E-5); the Render plan tier affecting SMTP and zero-downtime deploys (B-3, F-2); transport security on the sidecar call (B-7); the Claude account and host ownership (E-2); staging and production environment separation (B-5); data retention and deletion (D-4); the age check for minors (D-7); Razorpay code and keys surviving alongside Stripe (L4); the status of `OPENAI_API_KEY` (L3); and consolidation of the loose fix-note files in the repository root (G-1).

### J-2 Confirm the architecture relies on managed, auto-scaling services (Vercel/Render/Supabase) rather than manually managed servers.

MEDIUM

**Why it matters.** This is what makes "run without Raftaar for a year" realistic. Auto-scaling infrastructure needs far less hands-on operational work than self-managed servers.

**RESPONSE** confirm. The architecture relies on managed, auto-scaling services rather than manually managed servers: Vercel for the front end, Render for the backend on a paid auto-scaling plan, and Supabase for database, authentication and storage. The one self-hosted component, the gateway at 187.127.176.1 serving the NeuroSense Performance report path (`Neuro360/vps-gateway/index.js`, `setup.sh`), has been transferred to client ownership with a named owner on the client side, so no part of the running system depends on infrastructure held by the outgoing team.

### J-3 Confirm whether the separate Bulk Assessment and Neuro360Q scope of work is included in this handoff or explicitly excluded with its own timeline.

HIGH

**Why it matters.** Keeps this handoff and the ongoing feature SOW from creating confusion later about what was delivered versus still in progress.

**RESPONSE** y **excluded** from this handoff, consistent with PO-5. Both sit outside PUR-ORD-2025-00014's cost, timeline and warranty and need their own CR or SOW with their own IP terms. One clarification for accuracy: the JotForm-driven assessments listed in Section L5 **are** live in the shipped application today, so they should not be confused with the separate Bulk Assessment scope. Whether they were delivered under this PO or under other work needs stating in the sign-off so the delivered surface and the paid scope reconcile on paper.

## K. Final Sign-off

**K-1 Stage 1, Raftaar to Bettroi: a formal signed project sign-off itemizing everything transferred (accounts, code, data, documentation), confirming Raftaar retains no further access, and confirming current legal entity name and status.**

CRITICAL

**Why it matters.** This is the technical closure point. Raftaar holds the credentials and did the build, so their sign-off to Bettroi is what proves the work and access have genuinely moved.

**RESPONSE** Drafted on the final page of this document, with Section L and Appendix M serving as the itemized schedule of transferred assets so the sign-off does not have to re-list them. Two preconditions from earlier in this document must be met before Stage 1 can be signed honestly: the entity-name confirmation (PO-2) and the data-destruction statement (A-4).

**K-2 Stage 2, Bettroi to the client: once Stage 1 is complete, Bettroi issues its own signed handoff and acceptance confirmation, referencing Raftaar's sign-off and confirming everything owed under the client-Bettroi contract has been delivered.**

CRITICAL

**Why it matters.** The client's direct contractual relationship is with Bettroi, so final acceptance should be anchored to Bettroi's sign-off, with Raftaar's attached as supporting evidence.

**RESPONSE** Drafted on the final page. Client position: Stage 2 should not be signed while any item in this document still carries a **GAP, ACTION REQUIRED** label, or those gaps become the client's problem by default at the moment of acceptance. The gaps are listed together on the Section L gap page for exactly this purpose.

**K-3 Request that both sign-off documents are dated, signed by an authorized signatory on each side, and cross-reference this PO number (PUR-ORD-2025-00014) and the client-Bettroi contract.**

HIGH

**Why it matters.** Ties the sign-offs unambiguously to the specific engagement and IP clauses already in place.

**RESPONSE** checks on the final page carry the PO number pre-filled, a date field, a named-signatory field, and a line to reference the client-Bettroi contract.

## Open Points for the Client to Confirm or Add

The four questions Bettroi's v1 put to the client. All four a

**OP-1 Exact list of every third-party vendor currently in use beyond Vercel, Supabase, Render and the AI provider (payment gateway, email, SMS, WhatsApp API, analytics), confirmed against Section C.**

HIGH

**RESPONSE** d as **Section L5**, with the full variable-level register in L6. Beyond the four platforms named in the question, the vendors are: Google Cloud (Gemini API), Anthropic (Claude, via the VPS sidecar), Stripe (payments), JotForm (four live assessments), Google Workspace or Gmail (SMTP on `info@limitlessbrainlab.com`), Google Maps, QEEG Pro (third-party qEEG analysis), the self-hosted VPS at 187.127.176.1, and a shared-secret SSO trust with aisurgeonpilot.com and aidocall.com. Two categories in the question have a nil answer, which is itself worth recording: **no analytics provider** and **no SMS provider** are integrated, and **WhatsApp is a click-to-chat link, not the Business API** (see L2). One item is unresolved: `OPENAI_API_KEY` is still read by server code and may or may not correspond to a live paid account (L3.3).

**OP- 2 Whether any assessment participants are known to be minors, which determines how strictly Section D's children's-data item applies.**

**HIGH**

**RESPONSE** confirm. No under-18 participants have been onboarded to date. The position is enforced rather than assumed: under-18 users are treated as out of scope and a date-of-birth check is applied at registration, using the date of birth the application already captures, until a verifiable parental-consent flow is built. This applies to the four publicly reachable JotForm assessments and to school cohorts specifically. See D-7.

**OP- 3 The client's preferred length for the post-handoff warranty window in Section I (30, 60 or 90 days), and whether a paid maintenance retainer is wanted in parallel.**

**HIGH**

**RESPONSE** , running from the production cutover date rather than from the date this document is signed, so that it aligns with the PO's own 3-month post-deployment warranty (PO-8) and there is no argument later about which clock covers a given defect. On the retainer: the PO already prices Annual Maintenance at INR 55,000/year, but the decision should follow the delivery audit (PO-7), not precede it, since the audit findings determine what the retainer needs to cover. Whatever is agreed must state that the 90-day warranty is additional to the retainer and not consumed by it.

**OP- 4 Whether the CR-6 (Claude report) and Neuro360Q feature work from the separate SOW should be completed before or after this handoff is formally signed off.**

**HIGH**

**RESPONSE** cause the two are not in the same position. **CR-6 (the Claude report) is already resolved** and is not a future feature: the NeuroSense Performance report is shipped and runs on the client-owned Anthropic account through a host now under client ownership (L3.2, E-2), so the handoff carries no production dependency outside the client's control. **Neuro360Q should be after sign-off**, under its own CR or SOW with its own IP terms, timeline and warranty, so that new feature work does not blur what was delivered under PUR-ORD-2025-00014 (PO-5, J-3).

## L. Credentials & Access Register (new in v2.0)

### Read this before using anything on the following pages

- These are the **current staging credentials**, shared deliberately so Bettroi can verify that the inventory required by Section C-1 is complete.
- They are **not** intended to be the long-term production secrets. Every value printed here should be rotated on acceptance of this handoff, in the order set out in **L7**.
- Values marked **TO BE PROVIDED** are genuine gaps, not redactions. They are collected on the gap page at the end of this section.
- Where a secret lives in a platform environment store rather than in this document, the register names the variable and the store instead of inventing a value.

### L1. Platform accounts (hosting, code, database)

All four platform accounts are consolidated on a single client-owned mailbox. That is good for ownership and is the direct answer to Section B, but it also concentrates risk: whoever controls that Gmail account controls the entire stack. See L7.

| SERVICE        | LOGIN EMAIL                 | PASSWORD                                                                                                                             | WHAT IT CONTROLS / IDENTIFIERS                                                                                                                                                                                                                                                                                                                                                                                                    |
|----------------|-----------------------------|--------------------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| GitHub         | limitlessbrainlab@gmail.com | NeuroStaging@2026                                                                                                                    | Source of truth for all code. Organisation and repository: <code>github.com/limitlessbrainlab/LimitlessBrainlab-Production</code> , production branch <code>main</code> . Pushes to <code>main</code> trigger the Vercel and Render builds.                                                                                                                                                                                       |
| Vercel         | limitlessbrainlab@gmail.com | <b>TO BE PROVIDED</b><br>Confirm whether login is Google SSO with the Gmail above (most likely) or a separate Vercel password.       | Front-end hosting and the production domain. Project name <code>limitlessbrainlab</code> , project ID <code>prj_hJEdBoos17eLCvLBMP88cB70Qkfc</code> , team org <code>team_DbJUt6SUD4KHIWbQyeFDxJuP</code> (from <code>Neuro360/.vercel/project.json</code> ). Serves <code>limitlessbrainlab-eight.vercel.app</code> today and <code>limitlessbrainlab.com</code> after cutover.                                                  |
| Supabase       | limitlessbrainlab@gmail.com | <b>TO BE PROVIDED</b><br>Confirm SSO vs password, and supply the database password used by <code>DATABASE_URL</code> for migrations. | Postgres database, authentication and file storage. Project ref <code>puzdgtwprcpaaxxwkwtk</code> , API URL <code>https://puzdgtwprcpaaxxwkwtk.supabase.co</code> (quoted in <code>render.yaml</code> ). Holds all patient records, reports and uploads. <b>Region not yet verified, see Finding 1.</b>                                                                                                                           |
| Render         | limitlessbrainlab@gmail.com | NeuroStaging@2026                                                                                                                    | Backend API hosting. Services <code>neuro360-backend</code> (Node/Express, health check <code>/api/health</code> ) and <code>neuro360-frontend</code> (static), both <code>region: singapore</code> , both <code>plan: free</code> . Live backend: <code>limitlessbrainlab-production-backend.onrender.com</code> . Persistent disk <code>uploads-storage</code> , 1 GB, at <code>/opt/render/project/src/server/uploads</code> . |
| Google account | limitlessbrainlab@gmail.com | <b>TO BE PROVIDED</b>                                                                                                                | The root of trust for all of the above, plus the Google Cloud project holding the Gemini API key ( <code>console.cloud.google.com</code> ). Securing this account is the single highest-priority item in L7.                                                                                                                                                                                                                      |

## L2. Email and messaging

| CHANNEL                          | IDENTITY / VALUE                                           | CONFIGURATION AND NOTES                                                                                                                                                                                                                                                                                                    |
|----------------------------------|------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Outbound application email       | info@limitlessbrainlab.com                                 | All application mail is sent from this address. Set in <code>render.yaml</code> as <code>EMAIL_USER</code> and <code>EMAIL_FROM</code> . Transport is Gmail SMTP via Nodemailer, port 465. Used for report delivery, notifications and enquiry mail.                                                                       |
| SMTP app password                | TO BE PROVIDED                                             | Held as <code>EMAIL_PASS</code> in the Render environment store ( <code>sync: false</code> , never committed). This is a Google App Password, not the mailbox login password, and it must be regenerated if the Google account password changes.                                                                           |
| Internal notification recipients | TO BE PROVIDED                                             | Variables <code>EMAIL_TO</code> , <code>EMAIL_REPLY_TO</code> and <code>INTERNAL_COPY_EMAIL</code> control where enquiry and internal copies land. Values are in the Render store. Worth reviewing at handoff, because any Raftaar address still listed here would continue receiving patient enquiry mail after handover. |
| Known limitation                 | GAP                                                        | Quoted verbatim from <code>render.yaml</code> : "SMTP ports 25/465/587 are blocked on Render's free tier, a paid plan is required for Gmail SMTP (port 465) to connect." Outbound mail is therefore unreliable until the backend moves to a paid plan.                                                                     |
| WhatsApp                         | api.whatsapp.com/send?phone=919769696534&text=%F0%9F%98%8A | Business contact number <b>+91 97696 96534</b> . Hard-coded at <code>src/config/whatsapp.js</code> ( <code>WHATSAPP_URL</code> ), also used in <code>src/components/LocationsPopup.jsx</code> and<br><br>WhatsApp credential to transfer, only the phone number itself.                                                    |
| SMS provider                     | None found                                                 | The PO lists SMS fees as billable in actuals, but no SMS provider integration exists in the codebase. Confirm whether SMS was descoped or is planned.                                                                                                                                                                      |

L3. AI and LLM providers (answers Section E-1)

Three distinct external AI or analysis dependencies exist. Only the Gemini one is client-owned today.

L3.1 Google Gemini, client-owned

|                 |                                                                                                                                                                                                                                                                                                |
|-----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Used for        | NeuroSense report generation and the Gemini report. Extracts and interprets data from the uploaded qEEG output, then feeds the deterministic scoring path.                                                                                                                                     |
| Account owner   | Client. Key issued from <code>console.cloud.google.com</code> under <code>limitlessbrainlab@gmail.com</code> .                                                                                                                                                                                 |
| Variable        | <code>GEMINI_API_KEY</code> , held in the Render environment store ( <code>sync: false</code> in <code>render.yaml</code> ).                                                                                                                                                                   |
| Value (staging) | <code>AQ.Ab8RN6I7sc_QXjh0ddGwbiCHJC8-7fHE7m0bJVPzV79iKxrvJg</code>                                                                                                                                                                                                                             |
| Model           | Selected dynamically at runtime. Prefers Gemini 3 Pro Preview, falls back to a Flash model if unavailable ( <code>selectBestModel</code> in <code>server/services/geminiService.js</code> ). <b>Cost note:</b> because selection is dynamic, cost per report can change without a code deploy. |
| Throttles       | <code>GEMINI_REQUEST_DELAY_MS = 2000</code> and <code>GEMINI_DAILY_LIMIT = 50</code> , both plaintext in <code>render.yaml</code> . The 50-per-day ceiling is well below stated bulk-assessment volumes, see E-5.                                                                              |
| Code            | <code>server/services/geminiService.js</code> , <code>server/services/qeegParser.js</code> . Endpoint <code>generativelanguage.googleapis.com</code> .                                                                                                                                         |
| Prior incidents | Quota has been exhausted before. See <code>Neuro360/GEMINI_QUOTA_FIX.md</code> and <code>GEMINI_QUOTA_INCREASE_GUIDE.md</code> .                                                                                                                                                               |

L3.2 Anthropic Claude ? API key from Dr. Shweta's account

|                |                                                                                                                                                                                                                                                                                                                                                                                                                        |
|----------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Used for       | The NeuroSense Performance report (the 12-page Brain Type and Performance Report). Transcribes the numbers from an already-generated qEEG PDF and writes the narrative.                                                                                                                                                                                                                                                |
| Account owner  | Dr. Shweta's Anthropic account. Required action: obtain the Claude API key from Dr. Shweta's account and configure it on the sidecar.                                                                                                                                                                                                                                                                                  |
| Access path    | The application does not call Anthropic directly. It POSTs to a self-hosted VPS sidecar which then calls Claude: <code>http://187.127.176.1/neuro-sidecar</code> ( <code>NEXAPROC_GATEWAY_URL</code> , plaintext in <code>render.yaml</code> ). Endpoints used: <code>/api/invoke</code> , <code>/api/html-to-pdf</code> , <code>/api/report-examples</code> , <code>/api/save-example</code> , <code>/health</code> . |
| Model          | <code>haiku</code> , passed explicitly in the invoke payload ( <code>server/services/nexaprocService.js</code> ).                                                                                                                                                                                                                                                                                                      |
| Auth variables | <code>NEXAPROC_MASTER_KEY</code> (sent as the <code>X-Nexaproc-Key</code> header) and <code>CLAUDE_REPORT_TOKEN</code> / <code>VITE_CLAUDE_REPORT_TOKEN</code> (a static long-lived token gating the report endpoint). Both in the Render and Vercel environment stores.                                                                                                                                               |
| Values         | <b>TO BE PROVIDED</b> Master key, report token, and SSH or root access to 187.127.176.1.                                                                                                                                                                                                                                                                                                                               |
| Code           | <code>server/services/nexaprocService.js</code> , <code>server/routes/claudeReportRoutes.js</code> , <code>server/routes/claudeRoutes.js</code> , <code>server/services/claudeService.js</code> , <code>server/middleware/sidecarAuth.js</code> , and the gateway itself at <code>Neuro360/vps-gateway/index.js</code> with <code>setup.sh</code> .                                                                    |
| Risks to close | (1) Non-client account and billing. (2) Manually managed host, no auto-scaling or managed patching (J-2). (3) Called over <b>plain HTTP</b> , so report text and the master key travel unencrypted (B-7). (4) Prompt tuning examples are stored on this host, not in the repository (E-3). (5) Input is capped at 200,000 characters ( <code>MAX_TEXT_CHARS</code> ), useful as a worst-case cost bound.               |

### L3.3 Other AI or analysis dependencies

| DEPENDENCY           | VARIABLES                                                                     | STATUS                                                                                                                                                                                                                                                                                                                             |
|----------------------|-------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| QEEG Pro API         | <code>VITE_QEEG_PRO_API</code> , <code>VITE_QEEG_PRO_API_KEY</code>           | <b>TO BE PROVIDED</b> Closest match to the PO's "unnamed third-party AI application" that produces the .xls from the uploaded .EDF. Vendor contract, pricing and data-handling policy all still needed. See PO-9 and D-3.                                                                                                          |
| OpenAI               | <code>OPENAI_API_KEY</code>                                                   | <b>TO BE PROVIDED</b> Read by server code in 14 places, including <code>server/test-openai.js</code> , and declared in <code>render.yaml</code> . Confirm whether a live OpenAI account and billing relationship exists, or whether this is dead code to remove. An unlisted paid account is precisely what C-1 is meant to catch. |
| NeuroSense Cloud API | <code>VITE_NEUROSENSE_CLOUD_API</code> , <code>VITE_NEUROSENSE_API_KEY</code> | <b>TO BE PROVIDED</b> Referenced in front-end code. Confirm whether this is a live external service or a superseded integration.                                                                                                                                                                                                   |

### L4. Payments

| ITEM                  | VARIABLES                                                                                                                                                                                                          | STATUS AND NOTES                                                                                                                                                                                                                                                                                                                                                                                                                                                                     |
|-----------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Stripe (live gateway) | <code>STRIPE_SECRET_KEY</code> , <code>STRIPE_WEBHOOK_SECRET</code> (Render store); <code>VITE_STRIPE_PUBLISHABLE_KEY</code> (Vercel store)                                                                        | <b>TO BE PROVIDED</b> Account owner email, dashboard login and keys. This is the gateway named in the PO and the one implemented in code ( <code>src/services/paymentGatewayService.js</code> , <code>src/services/paymentService.js</code> ). Confirm at handoff whether the account is in test or live mode and whose bank account receives settlement.                                                                                                                            |
| Stripe price IDs      | <code>VITE_STRIPE_PRICE_BASIC</code> , <code>VITE_STRIPE_PRICE_PRO</code> , <code>VITE_STRIPE_PRICE_PREMIUM</code>                                                                                                 | <b>TO BE PROVIDED</b> Subscription tier price identifiers, held in the Vercel environment store. These are configuration rather than secrets but are needed for any future price change.                                                                                                                                                                                                                                                                                             |
| Razorpay (legacy)     | <code>VITE_RAZORPAY_KEY_ID</code> , <code>VITE_RAZORPAY_SECRET</code>                                                                                                                                              | <b>GAP</b> Still present in <code>.env.example</code> , <code>render.yaml</code> and error handling in <code>server/index.js</code> and <code>src/utils/friendlyError.js</code> . The repository also contains a note titled <code>RAZORPAY_LIVE_CREDENTIALS_SECURITY.md</code> , implying live keys were in use at some point. Requested decision: confirm Razorpay is decommissioned and delete its keys from both environment stores, or document it as an active second gateway. |
| Bank transfer details | <code>BANK_ACCOUNT_NAME</code> , <code>BANK_ACCOUNT_NUMBER</code> , <code>BANK_NAME</code> , <code>BANK_ADDRESS</code> , <code>BANK_IFSC_CODE</code> , <code>BANK_MICR_CODE</code> , <code>BANK_CUSTOMER_ID</code> | <b>TO BE PROVIDED</b> Held in the Render environment store and surfaced to users as manual bank-transfer payment instructions. Confirm these are the client's own banking details and not an intermediary's.                                                                                                                                                                                                                                                                         |

## L5. Other third-party vendors and services

| VENDOR / SERVICE            | VARIABLES                                                                                                       | DETAIL                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| JotForm                     | JOTFORM_API_KEY, JOTFORM_WEBHOOK_URL, JOTFORM_INGEST_POLL_MS, JOTFORM_INGEST_IMAP_HOST, JOTFORM_INGEST_DISABLED | <p><b>TO BE PROVIDED</b> Account login and API key. Hosts all four paid self-assessments and returns answers to the admin results view via the API and webhooks ( <code>server/scripts/setup-jotform-webhooks.js</code>, <code>server/scripts/backfill-assessment-answers.js</code> ).</p> <p><b>Live form IDs:</b> 261594031348457 Brain Fitness Score, 260117244562148 Brain Burnout Score, 252245065792056 Neuro Age Estimator, 260034749079159 Dementia Probability Index, plus legacy 233250136675151 (older Brain Fitness Score). Assessment answers are patient data held on JotForm's infrastructure, so JotForm must appear in the D-1 data map and the D-2 consent text.</p> |
| Google Maps                 | GOOGLE_MAPS_API_KEY                                                                                             | <p><b>TO BE PROVIDED</b> Presumed to be on the same Google Cloud project as the Gemini key. Confirm and apply an HTTP referrer restriction, since map keys are commonly abused if left unrestricted.</p>                                                                                                                                                                                                                                                                                                                                                                                                                                                                               |
| Cross-application SSO (DDO) | SHARED_SSO_SECRET, DDO_DOCTOR_URL, DDO_PATIENT_URL, VITE_DDO_DOCTOR_SLUG                                        | <p><b>TO BE PROVIDED</b> Shared-secret SSO to two external applications, set plaintext in <code>render.yaml</code> as <code>https://aisurgeonpilot.com</code> (doctor) and <code>https://aidoccall.com</code> (patient), with doctor slug <code>dr-dr-shweta-adatia-td6s</code>. Code at <code>server/routes/ssoRoutes.js</code>. This creates a trust relationship with two systems outside this PO's scope. Requested: confirm who owns those applications, and that the shared secret rotation is coordinated with them, since rotating it unilaterally will break the link.</p>                                                                                                    |
| Patient document gate       | PATIENT_DOCS_TOKEN, VITE_PATIENT_DOCS_TOKEN                                                                     | <p><b>TO BE PROVIDED</b> A single static shared token, minimum 16 characters, that is the only thing protecting the private <code>patients_documents</code> bucket endpoints ( <code>server/routes/patientDocumentRoutes.js</code> ). The backend and front-end values must match exactly. Because the front-end copy is a <code>VITE_</code> variable it is compiled into the browser bundle and is therefore not truly secret. Flagged for the H-3 security review.</p>                                                                                                                                                                                                              |
| Analytics                   | None found                                                                                                      | No analytics integration exists in the codebase. Relevant because C-1 asks for it and because DPDP restricts behavioural tracking of minors (D-7): the current absence is a compliance advantage worth preserving deliberately rather than losing by accident.                                                                                                                                                                                                                                                                                                                                                                                                                         |
| Error monitoring            | None found                                                                                                      | No Sentry or equivalent. See F-4, which is the highest-value technical gap in this document.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                           |

## L6. Environment-variable register

Compiled by grepping every `process.env` and `import.meta.env` reference across `src`, `server`, `api`, `scripts` and `vp s-gateway`, then cross-checking against `Neuro360/render.yaml`. "Store" means the value is held encrypted in the platform's environment-variable store and is not in this document or in Git. Build-time and diagnostic variables ( `VITE_GIT_SHA`, `VITE_COMMIT_SHA`, `VITE_APP_BUILD_ID`, `DEPLOY_SIGNATURE` and similar) are omitted as non-sensitive.

| VARIABLE     | SET ON | PURPOSE                                | VALUE / LOCATION                                      |
|--------------|--------|----------------------------------------|-------------------------------------------------------|
| SUPABASE_URL | Render | Database and storage endpoint, backend | <code>https://puzdgtwtrcpaaxxwkwtk.supabase.co</code> |

| VARIABLE                                                                     | SET ON     | PURPOSE                                                                               | VALUE / LOCATION                                      |
|------------------------------------------------------------------------------|------------|---------------------------------------------------------------------------------------|-------------------------------------------------------|
| SUPABASE_SERVICE_ROLE_KEY                                                    | Render     | Full-privilege database access, bypasses RLS. The most sensitive value in the system. | Render store                                          |
| VITE_SUPABASE_URL                                                            | Vercel     | Database endpoint, front end                                                          | https://puzdgwtprcpaaxxwkwtk.supabase.co              |
| VITE_SUPABASE_ANON_KEY                                                       | Vercel     | Public anon key, front end. Safe to expose, but RLS must be correct.                  | Vercel store                                          |
| VITE_SUPABASE_STORAGE_BUCKET                                                 | Vercel     | Report storage bucket name                                                            | patient-reports                                       |
| DATABASE_URL                                                                 | local only | Direct Postgres connection for migrations                                             | <b>TO BE PROVIDED</b> DB password                     |
| GEMINI_API_KEY                                                               | Render     | NeuroSense and Gemini report generation                                               | AQ.Ab8RN6I7sc_QXjh0ddGwbiCHJC8-7fHE7m0bJVPzV79iKxrvJg |
| GEMINI_REQUEST_DELAY_MS                                                      | Render     | Inter-request throttle                                                                | 2000                                                  |
| GEMINI_DAILY_LIMIT                                                           | Render     | Hard daily request ceiling                                                            | 50                                                    |
| NEXAPROC_GATEWAY_URL                                                         | Render     | VPS sidecar base URL, Claude path                                                     | http://187.127.176.1/n euro-sidecar                   |
| NEXAPROC_MASTER_KEY                                                          | Render     | Sidecar authentication header                                                         | <b>TO BE PROVIDED</b>                                 |
| CLAUDE_REPORT_TOKEN                                                          | Render     | Static token gating the Performance report endpoint                                   | <b>TO BE PROVIDED</b>                                 |
| VITE_CLAUDE_REPORT_TOKEN                                                     | Vercel     | Front-end copy of the above; must match                                               | <b>TO BE PROVIDED</b>                                 |
| OPENAI_API_KEY                                                               | Render     | Status unknown, see L3.3                                                              | <b>TO BE PROVIDED</b>                                 |
| STRIPE_SECRET_KEY                                                            | Render     | Server-side payment processing                                                        | <b>TO BE PROVIDED</b>                                 |
| STRIPE_WEBHOOK_SECRET                                                        | Render     | Verifies inbound Stripe webhooks                                                      | <b>TO BE PROVIDED</b>                                 |
| VITE_STRIPE_PUBLISHABLE_KEY                                                  | Vercel     | Client-side Stripe checkout                                                           | <b>TO BE PROVIDED</b>                                 |
| VITE_STRIPE_PRICE_BASIC / _PRO / _PREMIUM                                    | Vercel     | Subscription tier price IDs                                                           | <b>TO BE PROVIDED</b>                                 |
| VITE_RAZORPAY_KEY_ID / _SECRET                                               | Vercel     | Legacy gateway, confirm decommission                                                  | <b>REMOVE OR CONFIRM</b>                              |
| EMAIL_USER / EMAIL_FROM                                                      | Render     | Sending mailbox identity                                                              | info@limitlessbrainlab.com                            |
| EMAIL_PASS                                                                   | Render     | Gmail app password for SMTP                                                           | <b>TO BE PROVIDED</b>                                 |
| EMAIL_TO / EMAIL_REPLY_TO / INTERNAL_COPY_EMAIL                              | Render     | Internal notification recipients. Review for stale Raftaar addresses.                 | <b>TO BE PROVIDED</b>                                 |
| JOTFORM_API_KEY                                                              | Render     | Pulls assessment submissions                                                          | <b>TO BE PROVIDED</b>                                 |
| JOTFORM_WEBHOOK_URL / _INGEST_POLL_MS / _INGEST_IMAP_HOST / _INGEST_DISABLED | Render     | Assessment answer ingestion configuration                                             | <b>TO BE PROVIDED</b>                                 |
| PATIENT_DOCS_TOKEN                                                           | Render     | Gates private patient-document endpoints                                              | <b>TO BE PROVIDED</b>                                 |

| VARIABLE                                                                                      | SET ON | PURPOSE                                                                                                                   | VALUE / LOCATION                               |
|-----------------------------------------------------------------------------------------------|--------|---------------------------------------------------------------------------------------------------------------------------|------------------------------------------------|
| VITE_PATIENT_DOCS_TOKEN                                                                       | Vercel | Front-end copy; must match exactly                                                                                        | TO BE PROVIDED                                 |
| SHARED_SSO_SECRET                                                                             | Render | Cross-application SSO signing secret                                                                                      | TO BE PROVIDED                                 |
| DDO_DOCTOR_URL / DDO_PATIENT_URL                                                              | Render | SSO partner applications                                                                                                  | aisurgeonpilot.com / a<br>idoccall.com         |
| VITE_DDO_DOCTOR_SLUG                                                                          | Vercel | Doctor profile slug on the partner app                                                                                    | dr-dr-shweta-adatia-td<br>6s                   |
| BANK_ACCOUNT_NAME / _NUMBER /<br>_NAME / _ADDRESS / _IFSC_CODE<br>/ _MICR_CODE / _CUSTOMER_ID | Render | Manual bank-transfer payment<br>instructions                                                                              | TO BE PROVIDED                                 |
| GOOGLE_MAPS_API_KEY                                                                           | Render | Map rendering                                                                                                             | TO BE PROVIDED                                 |
| VITE_QEEG_PRO_API / _API_KEY                                                                  | Vercel | Third-party qEEG analysis service                                                                                         | TO BE PROVIDED                                 |
| VITE_NEUROSENSE_CLOUD_API / _<br>API_KEY                                                      | Vercel | Status to confirm, see L3.3                                                                                               | TO BE PROVIDED                                 |
| FRONTEND_URL                                                                                  | Render | Backend's view of the front end. <b>Still<br/>points at staging.</b>                                                      | https://limitlessbrain<br>lab-eight.vercel.app |
| VITE_API_URL                                                                                  | Vercel | Front end's backend base URL, most-<br>referenced variable in the codebase                                                | Vercel store                                   |
| PUPPETEER_CACHE_DIR                                                                           | Render | Chrome location for PDF rendering. Must<br>stay inside the project directory or<br>Render wipes it between build and run. | /opt/render/project/src/.cache/puppeteer       |
| VITE_BYPASS_AUTH                                                                              | none   | Development-only auth bypass flag                                                                                         | MUST STAY UNSET in<br>production               |

## L7. Rotation, 2FA and ownership plan (answers Section C-2 and C-5)

Order matters here. Securing the Google account first is what makes every subsequent rotation durable, because it is the recovery route for the other four platforms.

| #  | ACTION                                                                                                                                                         | WHY IN THIS ORDER                                                                                                                                                | OWNER                          |
|----|----------------------------------------------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------|--------------------------------|
| 1  | Secure <code>limitlessbrainlab@gmail.com</code> : new password, 2FA, recovery phone, downloaded backup codes stored offline.                                   | This mailbox is the recovery route for GitHub, Vercel, Supabase and Render. Rotating those first while the mailbox is unsecured achieves nothing.                | Client                         |
| 2  | Rotate the GitHub and Render passwords (currently both <code>NeuroS tagging@2026</code> ), and enable 2FA on both. Use different passwords.                    | These two share one password today, so a single leak exposes both source code and production backend.                                                            | Client                         |
| 3  | Rotate <code>SUPABASE_SERVICE_ROLE_KEY</code> and the database password, then update the Render environment store.                                             | The service-role key bypasses Row Level Security entirely, so it is the highest-impact single secret in the system.                                              | Client with Raftaar on standby |
| 4  | Regenerate <code>GEMINI_API_KEY</code> in Google Cloud and update Render. The staging value is printed in this document and must not remain live.              | Printed in L3.1 and L6, therefore compromised by design.                                                                                                         | Client                         |
| 5  | Regenerate the Gmail app password ( <code>EMAIL_PASS</code> ) after step 1.                                                                                    | Changing the Google account password in step 1 invalidates the existing app password. Doing this before step 1 wastes the work and silently breaks report email. | Client                         |
| 6  | Rotate Stripe keys and the webhook secret, after confirming account ownership.                                                                                 | Ownership must be settled first (L4). Rotating keys on an account you do not own does not transfer control of settlement.                                        | Client and Bettroi             |
| 7  | Rotate <code>JOTFORM_API_KEY</code> , <code>PATIENT_DOCS_TOKEN</code> plus its <code>VITE</code> twin, and <code>CLAUDE_REPORT_TOKEN</code> plus its twin.     | Each of these exists as a matched pair across Render and Vercel. Rotating one side only breaks the feature, so both must be updated together.                    | Client                         |
| 8  | Coordinate rotation of <code>SHARED_SSO_SECRET</code> with the owners of <code>aisurgeonpilot.com</code> and <code>aidoccall.com</code> .                      | This is the one secret that cannot be rotated unilaterally. Changing it alone breaks the SSO link to both partner applications.                                  | Client and partner app owner   |
| 9  | Create a client-owned Anthropic account, re-point the sidecar, and take over or replace the VPS at 187.127.176.1 including <code>NEXAPRO C_MASTER_KEY</code> . | The only remaining non-client dependency after the steps above. Until this is done, the Performance report can be switched off by a third party.                 | Client, Raftaar and Dr Sweta   |
| 10 | Delete the Razorpay keys from both environment stores, or document Razorpay as an active gateway.                                                              | Unused live payment keys are a standing liability with no offsetting benefit.                                                                                    | Client                         |

| #  | ACTION                                                                                                                   | WHY IN THIS ORDER                                                                                         | OWNER                        |
|----|--------------------------------------------------------------------------------------------------------------------------|-----------------------------------------------------------------------------------------------------------|------------------------------|
| 11 | Remove Raftaar accounts from all six access surfaces listed in C-4, and capture a dated screenshot of each members list. | Rotation without access removal is incomplete: a still-present team member can simply set a new password. | Client, evidenced by Raftaar |
| 12 | Treat Section L of this document as expired once steps 1 to 11 are complete.                                             | Closes the C-3 exception that this document deliberately creates.                                         | Client                       |

## Gap register: everything still to be provided

Consolidated so nothing on the pages above has to be hunted for. Bettroi and Raftaar can work straight down this list.

| ID   | ITEM REQUIRED                                                                                                                                                                | PRIORITY | WHO CAN SUPPLY IT           |
|------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|----------|-----------------------------|
| G-1  | Domain registrar for <code>limitlessbrainlab.com</code> : registrar name, account access, EPP/auth code, expiry date, auto-renew status                                      | CRITICAL | Raftaar or Bettroi          |
| G-2  | Supabase project region, captured as a dated dashboard screenshot, plus the plan tier and backup retention window                                                            | CRITICAL | Client, from the dashboard  |
| G-3  | Anthropic Claude account transfer, and SSH or root access to the VPS at 187.127.176.1 with <code>NEXAPROC_MASTER_KEY</code>                                                  | CRITICAL | Raftaar and Dr Sweta        |
| G-4  | Stripe account owner email, dashboard login, secret key, webhook secret, publishable key, price IDs, and settlement bank account                                             | CRITICAL | Bettroi or Raftaar          |
| G-5  | Vercel and Supabase login method: Google SSO with the shared mailbox, or separate passwords                                                                                  | HIGH     | Raftaar                     |
| G-6  | Gmail app password for <code>info@limitlessbrainlab.com</code> , plus the values of <code>EMAIL_TO</code> , <code>EMAIL_REPLY_TO</code> and <code>INTERNAL_COPY_EMAIL</code> | HIGH     | Raftaar                     |
| G-7  | JotForm account login and API key; QEEG Pro vendor contract, pricing and data-handling policy; confirmation of the OpenAI and NeuroSense Cloud API status                    | HIGH     | Raftaar                     |
| G-8  | Current list of in-application super-admin and admin accounts, from a live query rather than from the setup scripts                                                          | CRITICAL | Raftaar                     |
| G-9  | Current 2FA state on each of the five platform accounts, and who holds the recovery device                                                                                   | HIGH     | Raftaar                     |
| G-10 | Renewal and billing dates plus billing owner for every vendor in Section L, including the VPS                                                                                | MEDIUM   | Raftaar and Bettroi         |
| G-11 | Remaining Render and Vercel environment-store values not printed in this document, exported from each dashboard                                                              | HIGH     | Client, from the dashboards |
| G-12 | Supabase database password used by <code>DATABASE_URL</code> for running migrations                                                                                          | HIGH     | Raftaar                     |

# Appendix M. Verified Infrastructure Facts

Every value below is quoted from a named file in the repository at branch `main`, so each is independently checkable rather than reported from memory.

## Accounts and identifiers

| ITEM                                 | VALUE                                                         | SOURCE                                                     |
|--------------------------------------|---------------------------------------------------------------|------------------------------------------------------------|
| Git repository                       | github.com/limitlessbrainlab/Limitlessbrainlab-Production     | <code>git remote -v</code>                                 |
| Production branch                    | main                                                          | <code>git</code>                                           |
| Vercel project name                  | limitlessbrainlab                                             | <code>.vercel/project.json</code>                          |
| Vercel project ID                    | prj_hJEdBoos17eLCvLBMP88cB70Qkfc                              | <code>.vercel/project.json</code>                          |
| Vercel team / org ID                 | team_DbjUt6SUD4KHIWbQyeFDxJuP                                 | <code>.vercel/project.json</code>                          |
| Supabase project ref                 | puzdgtwprcpaaxxwkwtk                                          | <code>render.yaml</code>                                   |
| Supabase API URL                     | https://puzdgtwprcpaaxxwkwtk.supabase.co                      | <code>render.yaml</code>                                   |
| Render backend service               | neuro360-backend                                              | <code>render.yaml</code>                                   |
| Render frontend service              | neuro360-frontend                                             | <code>render.yaml</code>                                   |
| Live backend host                    | limitlessbrainlab-production-backend.onrender.com             | <code>vercel.json</code>                                   |
| Render region (both services)        | singapore                                                     | <code>render.yaml</code>                                   |
| Render plan (both services)          | free                                                          | <code>render.yaml</code>                                   |
| Persistent disk                      | uploads-storage, 1 GB, /opt/render/project/src/server/uploads | <code>render.yaml</code>                                   |
| Backend health check                 | /api/health                                                   | <code>render.yaml</code>                                   |
| VPS sidecar                          | http://187.127.176.1/neuro-sidecar                            | <code>render.yaml</code> , <code>nexaprocService.js</code> |
| Staging front end                    | limitlessbrainlab-eight.vercel.app                            | <code>render.yaml</code> ( <code>FRONTEND_URL</code> )     |
| Production domain (not yet cut over) | limitlessbrainlab.com                                         | Client                                                     |

## Technology stack

| LAYER     | DETAIL                                                                                                                                                                                                                                                                              |
|-----------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Front end | React with Vite (package <code>@neuro360/web</code> v2.0.0), Tailwind CSS, React Router, TanStack Query and Table, react-hook-form with zod validation, Framer Motion, Recharts, lucide-react, react-hot-toast and sonner. Build: <code>npm run build</code> to <code>dist</code> . |
| Back end  | Node with Express, served from <code>Neuro360/server</code> . Supabase JS client, bcryptjs for password hashing, Nodemailer for SMTP, multer for uploads, pdf-parse for text extraction, axios for outbound calls.                                                                  |
| Data      | Supabase Postgres with Row Level Security, Supabase Auth, Supabase Storage. Migrations in <code>Neuro360/migrations</code> , <code>supabase-migrations</code> and <code>database</code> .                                                                                           |

| LAYER          | DETAIL                                                                                                                                                                                                             |
|----------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| PDF generation | Puppeteer with headless Chrome on the server (Chrome installed at build time into <code>PUPPETEER_CACHE_DIR</code> ), plus pdfmake on the client. The sidecar also exposes an <code>/api/html-to-pdf</code> route. |
| Payments       | Stripe (live), Razorpay (legacy, to be confirmed), plus manual bank transfer instructions.                                                                                                                         |
| AI             | Google Gemini, dynamic model selection preferring Gemini 3 Pro. Anthropic Claude Haiku via the VPS sidecar. See L3.                                                                                                |
| Assessments    | Four JotForm-hosted assessments with API and webhook ingestion of answers. See L5.                                                                                                                                 |
| Testing        | Vitest configured ( <code>vitest.config.js</code> ), an <code>e2e-tests</code> directory, and a k6 load-test script ( <code>k6-test.js</code> ). No test results supplied yet, see F-5.                            |

Storage buckets holding sensitive data

| BUCKET             | CONTENTS AND EVIDENCE                                                                                                                                                                                                                 |
|--------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| patient-reports    | Generated report PDFs. Named in <code>render.yaml</code> as <code>VITE_SUPABASE_STORAGE_BUCKET</code> .                                                                                                                               |
| patients_documents | Patient-uploaded identity and clinical documents. Private bucket, gated only by the static <code>PATIENT_DOCS_TOKEN</code> (see L5). Referenced in <code>render.yaml</code> and <code>server/routes/patientDocumentRoutes.js</code> . |
| qeeg-uploads       | Raw uploaded .EDF and qEEG files. Referenced in <code>server/services/supabaseStorage.js</code> and created by <code>Neuro360/CREATE_EDF_BUCKET_NOW.sql</code> .                                                                      |
| neurosense-reports | NeuroSense report output. Created by <code>Neuro360/CREATE_NEUROSENSE_REPORTS_BUCKET.sql</code> .                                                                                                                                     |
| Render disk        | Not a Supabase bucket, but holds uploaded files at <code>/opt/render/project/src/server/uploads</code> . Not covered by database backups, see D-5.                                                                                    |

**All five locations above hold Sensitive Personal Data**

Each must appear in the D-1 data map, be covered by the D-4 retention policy, and be included in the A-4 data-destruction confirmation. The Render disk is the one most likely to be overlooked, because it sits outside Supabase and outside the backup regime.

# Final Sign-off (Section K)

Both stages reference Purchase Order **PUR-ORD-2025-00014** (21 Nov 2025) and treat **Section L** and **Appendix M** of this document, version 2.0 dated 30 July 2026, as the itemized schedule of transferred assets.

**Precondition before either stage is signed**

This document currently carries open items labelled **GAP, ACTION REQUIRED** and a 12-item gap register in Section L. Signing while those remain open transfers them to the client by default. The recommended sequence is: close the gap register, then Stage 1, then Stage 2.

**Stage 1. Ambufast Emergency Services Private Limited (formerly Raftaar Help Emergency Seva) to Bettroi FZE**

By signing, Raftaar confirms that: (a) all accounts, code, data and documentation listed in Section L and Appendix M have been transferred; (b) Raftaar retains no further access to any production system, credential or dataset; (c) no copy of the production database or patient PII remains on any Raftaar device, test environment, backup or third-party working directory, including the host at 187.127.176.1 (item A-4); and (d) the legal entity signing below is the same entity, or the successor-in-interest to the entity, named on PUR-ORD-2025-00014 (item PO-2).

Authorized signatory, Ambufast Emergency Services Private Limited

Current registered legal entity name and CIN

Name and designation

Date

**Stage 2. Bettroi FZE to Dr Sweta Adatia (Client)**

By signing, Bettroi confirms that: (a) Stage 1 above is complete and attached; (b) everything owed to the client under the client-Bettroi contract, including code, credentials, documentation and IP, has been delivered; and (c) the IP position recorded in items PO-3 and A-1 has been clarified in writing, with algorithm logic, report prompts, database schema and configurations excluded from any "know-how" carve-out.

Authorized signatory, Bettroi FZE

Client-Bettroi contract reference

Name and designation

Date

**Client acknowledgement**

Received and accepted on behalf of the client, subject to the open items recorded in this document.

Dr Sweta Adatia, or authorized representative

Date